



Instituto Politécnico Nacional
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:
Gobierno de TI | Computer Security

Tarea 14: “Análisis de vulnerabilidades”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

¿Que es CVSS?

CVSS es estándar abierto de FIRST/NIST que mide severidad de vulnerabilidades. Asigna puntuaciones 0-10: 0 (None), 3.9 (Low), 6.9 (Medium), 8.9 (High), 10 (critical). Facilita comunicación consistente entre organizaciones permitiendo priorizar remediación basada en riesgo real. Es estándar en National Vulnerability Database (NVD). [1][2][3].

Métrica base

Características intrínsecas constantes en tiempo y ambientes. Exploitability: Attack Vector, Complexity, Privileges Required, User interaction. [2]

Impact: Confidentiality, Integrity, Availability.

Producen Base Score que NVD utiliza para determinar severidad inicial. RCE remoto sin autenticación es igual a puntuación muy alta. [1][3].

Métrica temporal

Características que cambian con tiempo pero no entre ambientes. Exploit Code Maturity: disponibilidad de código malicioso. Remediation Level: disponibilidad de parches. Report Confidence: credibilidad de reportes técnicos. Se combinan con base score para ajustar severidad. [1][2][3].

Métrica Ambiental

Adaptan CVSS a ambiente organizacional específico.
Confidentiality / Integrity / Availability Requirements según criticidad en el sistema. Modificad Metrics para controles locales: WAF, firewall, segmentación + Servidor crítico recibe mayor puntuación que desarrollo. Permite priorización realista. [1][2][4]

OpenSSH (CVE-2024-4387)

Identificador: CVE-2024-4387 (regreSSHion)

Software: OpenSSH 8.5p1-9.7p1 en Linux glibc

CVSS: 8.1-9.8 (critical)

Descripción: Carrera de condiciones en handler SIGALRM permite RCE no autenticado como root. Cuando cliente no se autentica en loginGraceTime, funciones no async-signal-safe son llamadas. Primera RCE en OpenSSH en 20 años.

Solución: Actualizar a OpenSSH 9.8p1+ (julio 2024).

Mitigación: loginGraceTime = 0 en sshd-config, pero aumenta riesgo DoS. No vulnerable en OpenBSD.
[1][2][3]

Apache Tomcat (CVE-2024-23672)

Identificador: CVE-2024-23672

Software: Apache Tomcat 7.0-109, 8.5-100, 9.0-127, 10.1-26, 11.0-19.

CVSS: 7.5 (High)

Descripción: Negación de servicio (DoS) por incomplete cleanup de WebSocket connections. Conexiones malformadas causan agotamiento memoria / CPU. Servicio se vuelve no disponible por fallo en preasumiento. [1][2][3].

Solución: Actualizar a Tomcat 11.0.20, 10.1.53, 9.0.116+ (diciembre 2024). **Mitigación:** rate limiting, limitar conexiones WebSocket, monitorizar memoria. [4][5]

Windows NTLM (CVE-2024-43451)

Identificador: CVE-2024-43451

Software: Windows 10, 11, Server 2019/2022 (componente MSHTML legacy)

CVSS: 7.0-7.5 (High)

Descripción: Disclosure hashes NTLMv2 vía archivos .url/.library-ms malformados. Con mínima interacción (right-click), conexión SMB captura hashes. Usables en relay attacks.

Solución: Patch Microsoft noviembre 2024 (KB5046305).

Mitigación: deshabilitar MSHTML, bloquear puerto 445, usar Kerberos. Explotado activamente por APT 28

[1][4][7]

Referencias

- [1]. Qualys. (2024). regreSSHion CVE-2024-6387. <https://www.qualys.com/regresshion-cve-2024-6387>
- [2]. NIST NVD. (2024). National Vulnerability Database. <https://nvd.nist.gov/>
- [3]. TechTarget. (2024). CVSS Definition. <https://www.techtarget.com/searchsecurity/>
- [4]. Orca Security. (2025). CVSS Guide. <https://orca.security/glossary/>
- [5]. Fortinet. (2025). CVSS Glossary. <https://www.fortinet.com/resources/>
- [6]. Apache Tomcat. (2024). Security Bulletins. <https://tomcat.apache.org/>
- [7]. Check Point. (2025). NTLM Research. <https://research.checkpoint.com/>